



EMURUA DIKIRR TECHNICAL TRAINING INSTITUTE

Institute Management System (IMS) Board Presentation Question and Answer Guide

Audience: Board of Governors and stakeholders | Confidential, for presenter preparation

How to use this guide

This document anticipates the questions the board is most likely to ask and gives a clear, honest answer for each. Where a control is already in place, the answer says so plainly. Where work is still planned before or shortly after go live, the answer says that too, because the board will trust a candid position far more than an overstated one. Answers are grouped into five themes: the system itself, data protection and the Kenya Data Protection Act, security, infrastructure and availability, and governance and cost.

Section A. The system

A1. What is the Institute Management System and what problem does it solve? The Institute Management System, IMS, is the institute's single platform for managing students, trainers, departments, programs, fees, and academic operations. It replaces scattered spreadsheets and manual paperwork with one secure system that each office accesses through its own role based portal. The result is accurate records, faster service to students, and reliable reporting for management and the board.

A2. Who uses the system and how is access separated? Access is organised into role based portals. The current roles are administrator, registrar, finance, dean, deputy principal, industrial liaison office, CIBEC, head of department, trainer, and student. Each person sees only the functions and data their role requires. A trainer cannot open finance, a student can only see their own record, and only administrators manage system wide settings.

A3. Is this built and maintained in house? Yes. The platform was designed and built by the institute's own technical team, which means there are no recurring license fees to an outside vendor and the institute retains full ownership of its data and source code.

A4. What happens to the legacy data and processes? Existing records are migrated into the system in a controlled manner, and the manual processes are retired only once the equivalent function in the system has been verified. The system keeps an audit trail so historical activity remains traceable.

Section B. Data protection and the Kenya Data Protection Act, 2019

B1. Does the system comply with the Kenya Data Protection Act, 2019? The system is built around the principles of the Act. Personal data is collected for clear institutional purposes, only the data needed is collected, access is restricted by role, and the data is protected in transit and at rest. The remaining formal steps, described in the answers below, are registration with the Office of the Data Protection Commissioner and the appointment of a data protection officer, which are institutional actions rather than software features.

B2. Has the institute registered with the Office of the Data Protection Commissioner? Under the Act, an institution that processes personal data at this scale is expected to register as a data controller with the Office of the Data Protection Commissioner. The recommendation to the board is to complete or confirm this registration before the system serves the full student population, and to budget for the annual obligations that come with it.

B3. What personal data does the system hold? The system holds the data needed to run the institute: student identity and contact details, admission numbers, programme and academic records, fee and payment records, trainer and staff records, and documents that students and trainers upload. It does not collect data that the institute has no operational reason to hold.

B4. What is the lawful basis for processing this data? The lawful basis is the legitimate operation of an accredited public training institution and the contract of enrolment between the student and the institute, supported by consent captured at registration. Students are told what data is collected and why.

B5. How is the data protected? Several layers protect the data. Connections use encrypted transport. Passwords are never stored in readable form, they are stored using a strong one way hashing algorithm. Staff sign in requires a second factor, a one time code sent to their email, in addition to their password. Access is controlled by role, and each office only reaches the records it needs. The database is hosted on a managed, access controlled service, and uploaded files are stored in controlled object storage that is not openly browsable.

B6. What rights do students and staff have over their data? Under the Act, data subjects have the right to be informed, to access their data, to have inaccurate data corrected, to request deletion where there is no lawful reason to keep it, and to object to certain processing. The institute will honour these requests through the registrar's office, and the system makes the underlying records easy to locate and correct.

B7. How long is data kept? Academic and financial records are retained for the period required by education and audit regulations, after which they are archived or removed. The institute should adopt a written retention schedule so the practice is documented and consistent.

B8. Where is the data physically stored, and does it leave Kenya? The managed database and the file storage are operated by reputable cloud providers, and some of this infrastructure is located outside Kenya. The Act permits cross border transfer where appropriate safeguards exist. The recommendation is to record this transfer in the institute's data protection documentation, confirm the providers offer the required contractual safeguards, and disclose it in the privacy notice, so the position is transparent and defensible.

B9. What happens if there is a data breach? The Act expects a data controller to notify the Office of the Data Protection Commissioner without undue delay, and within seventy two hours where feasible, and to inform affected individuals where there is a real risk to them. The institute should adopt a short written

incident response procedure that names who is contacted, who assesses the impact, and who notifies the regulator, so a response is orderly rather than improvised.

B10. Who are the third parties that touch the data, and are they controlled? The system uses a managed database provider, a file storage provider, and an email delivery provider. Each is a data processor acting on the institute's instructions. The institute should hold a data processing agreement with each, which these providers offer as standard, and keep the list current.

B11. Are minors handled differently? Where any student is below the age of majority, the Act gives additional protection and expects consent from a parent or guardian. The registration process should capture guardian consent where this applies.

Section C. Security

C1. How do you know the system is secure and not just assumed to be? The platform has undergone a structured security review that examined every portal and every interface an attacker could reach, from the perspective of an outsider, a logged in user trying to exceed their role, and a malicious insider. Issues identified in that review were addressed, and the security posture is documented. Security is treated as an ongoing practice, not a one time event.

C2. Can a student or an outsider tamper with the system using browser tools? No. Changing what appears on screen in a browser does not grant any real access, because every action is checked again on the server. The server confirms who you are, confirms your role, and confirms that the specific record belongs to you before it does anything. A student editing the page in their browser cannot read another student's record or change a fee, because the server rejects the request.

C3. What stops someone from guessing passwords or one time codes? Sign in attempts are rate limited, repeated failures lock the account, and the one time codes are limited to a small number of attempts before they are cancelled. The codes themselves are stored only in hashed form and expire quickly. Staff accounts additionally require the second factor described earlier.

C4. How are the different portals kept separate so one cannot impersonate another? Each portal issues its own scoped session, and the server attaches a role to every session. A request is allowed only if its role is permitted for that function. Sessions can be revoked centrally, so when a member of staff leaves or changes role, their access changes immediately.

C5. What protects against common web attacks? The application uses parameterized database queries, which prevent injection of malicious database commands. It protects state changing actions with an anti forgery token so a malicious site cannot act on a logged in user's behalf. It validates uploaded files by inspecting their actual content rather than trusting the file name. It sets the standard browser security headers, and it limits request sizes to resist flooding.

C6. Are passwords or codes ever visible to administrators or in logs? No. Passwords are stored only as a one way hash and cannot be read back. One time codes are stored hashed and expire. The system is written so that passwords, codes, and tokens are never written to logs.

C7. What about the items the security review flagged for production? The review identified a small number of production settings that must be switched on at deployment, such as enforcing the secure flag on

cookies over the encrypted connection and moving the content security policy from reporting mode to enforcing mode after a short observation window. These are configuration steps for the production environment and are on the go live checklist. Being open about them is part of good security governance.

Section D. Infrastructure, availability, and scalability

D1. Where is the system hosted and is it reliable? The system runs on managed cloud infrastructure with an encrypted public address. Managed hosting means the provider handles the underlying servers, patching, and uptime, which is more reliable and lower maintenance than a single machine on campus.

D2. Will it cope when the whole student body logs in at once, for example during registration or results release? The architecture separates the application from the database and the file storage, so each can be scaled. The database provider scales to handle bursts, files are served from storage built for high demand, and the rate limits are tuned so that a large group of legitimate users sharing the campus connection are not mistaken for an attack.

D3. What is the backup and recovery position? The managed database provides point in time recovery, so the institute can restore to a moment before an incident. The recommendation is to confirm the backup retention window with the provider, document the recovery procedure, and test a restore at least once so the board has evidence it works.

D4. What happens if the internet or a provider goes down? Because the system is cloud hosted, a campus power or network outage does not lose data, the data remains safe with the provider and is reachable again once connectivity returns. For provider outages, the managed services carry their own redundancy, and the documented recovery procedure covers the rare worst case.

D5. Who maintains it and what is the support plan? The in house technical team maintains the system. The recommendation is to document the support arrangement, including who responds to issues and how quickly, so the institute is not dependent on a single individual.

Section E. Governance, cost, and risk

E1. What does the system cost to run? The main running costs are the managed database, file storage, and email delivery, which scale with usage, plus the staff time to maintain the system. There are no per user license fees because the platform is owned by the institute.

E2. What are the main risks and how are they managed? The principal risks are a data breach, prolonged downtime, and key person dependency. These are managed by the security controls and review described above, by managed hosting with backups, and by documenting procedures so knowledge is not held by one person. Completing the data protection registration and appointing a data protection officer closes the main compliance risk.

E3. What do you need from the board today? Endorsement to proceed to go live on the agreed date, approval to complete the data protection registration and appoint a data protection officer, and approval of the modest recurring infrastructure budget. With these in place the institute will be operating a secure, compliant, and institute owned management system.

One paragraph summary for the presenter

The Institute Management System is a secure, role based platform built and owned by Emurua Dikirr Technical Training Institute. It protects personal data with encryption, hashed passwords, staff two factor sign in, strict role based access, and defences against the common web attacks, and it has been through a structured security review. The remaining steps before full rollout are institutional rather than technical: registering with the Office of the Data Protection Commissioner, appointing a data protection officer, documenting the retention and incident procedures, and confirming the production configuration on the go live checklist. The platform is reliable, scalable, and far more cost effective than a licensed vendor product because the institute owns it outright.